

XSS

Seguridad en Aplicaciones Web Programacion Cross-Site (o XSS)

Ing. Pável Cáceres

Definición:

Cross-Site Scripting (XSS) es una vulnerabilidad de seguridad en aplicaciones web que permite a un atacante inyectar scripts maliciosos (generalmente JavaScript) en páginas web vistas por otros usuarios.

- **Reflejado (Reflected):** El script malicioso viene en una URL o formulario y es reflejado directamente en la respuesta.
- **Persistente (Stored):** El script malicioso se guarda en la base de datos o servidor y afecta a múltiples usuarios.

XSS Reflejado (reflected)

XSS Reflejado (reflected)

formulario.php

```
1  <!DOCTYPE html>
2  <html>
3  <head>
4      <meta charset="utf-8">
5      <meta name="viewport" content="width=device-width, initial-scale=1">
6      <title>Formulario</title>
7  </head>
8  <body>
9
10     <form method="GET" action="procesar.php">
11         <label>Escribe tu nombre:</label>
12         <input type="text" name="nombre">
13         <button type="submit">Enviar</button>
14     </form>
15
16 </body>
17 </html>
```

XSS Reflejado (reflected)

procesar.php

```
1 <?php
2 $nombre = $_GET['nombre'];
3 echo "Hola, $nombre!";
4 ?>
```

Ejecutar: procesar.php?nombre=<script>alert('XSS!')</script>

XSS Persistente (stored)

XSS Persistente (stored)

formulario.php

```
1  <!DOCTYPE html>
2  <html>
3  <head>
4      <meta charset="utf-8">
5      <meta name="viewport" content="width=device-width, initial-scale=1">
6      <title>Formulario</title>
7  </head>
8  <body>
9
10     <form method="POST" action="guardar.php">
11         <label>Comentario:</label>
12         <textarea name="comentario"></textarea>
13         <button type="submit">Guardar</button>
14     </form>
15
16 </body>
17 </html>
```

XSS Persistente (stored)

guardar.php

```
1  <?php
2  $comentario = $_POST['comentario'];
3  file_put_contents("comentarios.txt", $comentario . "\n", FILE_APPEND);
4  echo "Comentario guardado. <a href='ver.php'>Ver comentarios</a>";
5  ?>
```

ver.php

```
1  <?php
2  $comentarios = file("comentarios.txt");
3  ▼ foreach ($comentarios as $comentario) {
4      echo "<p>$comentario</p>";
5  }
6  ?>
```


XSS Persistente (stored)

Ejecutar en comentario:

```
<script>alert('XSS Persistente!')</script>
```

Prevención XSS

XSS Reflejado (reflected)

htmlspecialchars:

```
$nombre = htmlspecialchars($_GET['nombre'], ENT_QUOTES, 'UTF-8');  
echo "Hola, $nombre!";
```

función de PHP que **convierte caracteres especiales en entidades HTML**. Se usa principalmente para **prevenir ataques XSS** cuando se muestran datos que provienen del usuario en páginas web.

<	<
>	>
"	"
'	'
&	&

XSS Persistente (stored)

Recepcion de variable / Filtrar y sanitizar:

```
$comentario = filter_input(INPUT_POST, 'comentario',  
FILTER_SANITIZE_FULL_SPECIAL_CHARS);
```

filter_input: Obtiene y filtra datos de entrada de forma segura.

INPUT_POST: Indica que el dato viene por método POST.

FILTER_SANITIZE_FULL_SPECIAL_CHARS: Convierte caracteres especiales en sus entidades HTML para evitar XSS.

<	<
>	>
"	"
'	'
&	&

Trabajo XSS

XSS Persistente y su prevención en aplicaciones PHP/MySQL

Version vulnerable

- Crea una tabla comentarios (id,contenido)
- Desarrollar un formulario HTML en PHP que permita al usuario enviar comentarios.
- Insertar el contenido directamente en la base de datos sin aplicar validación ni sanitización.
- Mostrar los comentarios directamente en el navegador.
- Ingresar un comentario malicioso con código JavaScript

Version NO vulnerable

- Corrige la vulnerabilidad planteada en la versión anterior

